

**INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY
(ICDFA)**

GRC102: INFORMATION SECURITY GOVERNANCE

Week 2 Practical Laboratory

Principles of Information Security Governance

Full Name	MERCY RACHAEL AJAYI
Registration Number	C11/26/CGRCE/17219
Cohort / Batch	CGRCE Cohort 11
Course Title	Information Security Governance
Date Submitted	18th September, 2026

Introduction

NexusTech Solutions is a fast-growing software company that develops cloud-based ERP systems for clients in the financial and healthcare sectors. The company has grown from 50 employees to 250 in a short period, but its security documentation has not kept up with this growth. Its main security document is a five-year-old "IT Rules" document that combines policy statements, technical instructions and general recommendations in one file. As a result, employees and managers are not always clear about what is mandatory, what is only a recommendation, or who is responsible for specific security activities.

As the newly appointed Information Security Manager, my task in this lab is to address these gaps by developing a more structured and maintainable security policy framework. The framework will follow the Security Policy Development Lifecycle covered in GRC102 Week 2 and support NexusTech's ISO/IEC 27001 and SOC 2 goals.

This report covers five tasks. These include separating the security documentation into policies, standards, guidelines and procedures, developing an Acceptable Use Policy, creating a User Access Request Procedure, preparing a Communication and Training Plan, and writing a Policy Review and Maintenance Memo. I have used the laboratory brief as the main source and referred to ISO/IEC 27001, ISO/IEC 27002, NIST CSF 2.0 and SOC 2 where they are relevant to the work. ISO/IEC 27002 explains that "A control is defined as a measure that modifies or maintains risk" (International Organization for Standardization, 2022b). This connects to the purpose of the documents developed in this report, as they are intended to help NexusTech manage its security risks in a clear and organised way.

Evidence Bundle 1: Policy Hierarchy and Classification

Task 1.1 Hierarchy Definition Table

The table below shows the difference between the four types of security documents and how they would be used at NexusTech.

Document Type	Purpose	Authority	Rule Status	Level of Detail	NexusTech example
Policy	States the organisation's overall position on a security issue. It explains what is required and why it matters.	Usually approved by senior management or the CEO.	Mandatory	High level. It focuses on what should be done rather than technical steps.	Acceptable Use Policy or Information Security Policy
Standard	Supports a policy by setting specific and measurable requirements that users, systems or teams must meet.	Usually approved by the relevant security or IT leadership.	Mandatory within its scope	More specific than a policy. It can include settings, thresholds and other requirements.	Password Standard requiring passwords to be at least 14 characters
Guideline	Provides recommended practices that help employees make better security decisions.	Usually issued by the Information Security or IT team.	Recommended, not mandatory	Practical advice without requiring a fixed process.	Guidance on avoiding public, unsecured Wi-Fi
Procedure	Explains how to complete a specific task by providing clear steps to follow	Usually owned by the team responsible for the task.	Mandatory for people performing the task	Detailed and action-based.	User Access Request Procedure or MFA enrolment procedure

The four levels are related, but they serve different purposes. A policy states the overall requirement, a standard adds specific requirements, a guideline provides advice, and a procedure explains the steps for carrying out a task.

Task 1.2 Categorisation of the Eight Statements

S/N	Statement	Classification	Justification
1	All NexusTech employees must use multi-factor authentication when accessing the corporate network remotely.	Standard	This is a specific and mandatory security requirement for remote access.
2	To configure multi-factor authentication on your mobile device, download the Authenticator app, scan the QR code provided in the IT portal, and enter the six-digit verification code.	Procedure	It gives a series of steps for completing a specific task, which is what a procedure is meant to do.
3	It is recommended that developers use parameterised queries to reduce SQL injection risk.	Guideline	The use of "recommended" shows that this is advice rather than a mandatory requirement.
4	NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.	Policy	This is a broad statement of the organisation's security commitment without technical details.
5	All corporate laptops must have full disk encryption enabled using BitLocker on Windows or FileVault on macOS.	Standard	It gives a specific mandatory technical requirement for corporate laptops.
6	Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.	Guideline	The word "should" makes this recommended behaviour rather than a compulsory requirement.
7	In the event of a suspected security breach, employees must immediately contact the IT Helpdesk at extension 5555.	Procedure	This directs employees to take a specific action when a suspected security breach occurs.
8	Passwords must be a minimum of 14 characters and contain at least one uppercase letter, one lowercase letter, one number and one special character.	Standard	It sets specific and measurable password requirements that can be checked and enforced.

Task 1.3 Hierarchy Diagram

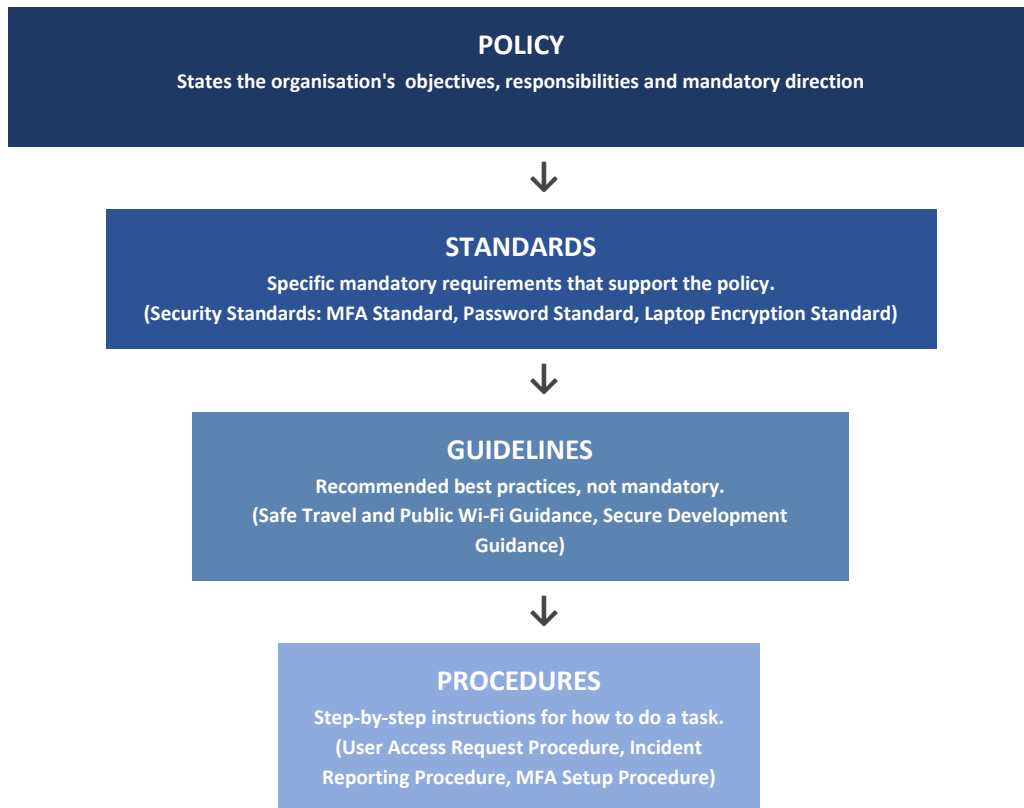


Figure 1. NexusTech documentation hierarchy. Scope narrows and operational detail increases moving from Policy down to Procedure.

Evidence Bundle 2: Acceptable Use Policy

NexusTech Solutions Acceptable Use Policy

Document Control

Field	Entry
Policy Title	Acceptable Use Policy
Policy Owner	Information Security Manager
Status	Approved
Approval Authority	Marcus Vance, CEO
Version	1.0
Effective Date	18 September 2026
Review Date	18 September 2027, or earlier if there is a major change

1. Purpose

The purpose of this Acceptable Use Policy is to explain how NexusTech employees and other authorised users should use company devices, networks, email, applications and other IT resources. The policy is intended to support normal business activities while reducing the risks of unauthorised access, malware, data loss and misuse of company systems.

2. Scope

This policy applies to all NexusTech employees, contractors, temporary workers, interns and other authorised users of NexusTech information resources. It applies whether they are working in the office, remotely or while travelling. It covers company devices, corporate networks, email accounts, applications, cloud services, removable media and company or client information handled by users.

3. Acceptable Use Requirements

Users must use NexusTech resources mainly for authorised business purposes and must take reasonable steps to protect company and client information.

The following rules apply:

- Users must only use accounts, devices, applications and services they are authorised to access.
- Users must keep their passwords, MFA devices and other authentication information secure and must not share them with anyone else.
- Users must lock their devices when leaving them unattended.

- Users must store and share company and client information through approved company systems. Personal email and personal cloud storage must not be used for this purpose.
- Users must use software approved by IT and follow security instructions provided by IT and Information Security.
- Users must report suspected phishing, malware, lost devices, unauthorised access or accidental disclosure to the IT Helpdesk or Information Security.
- Users must follow applicable laws and other approved NexusTech security policies.

4. Prohibited Activities

Users must not:

- Access another person's account, files or systems without authorisation.
- Share passwords, MFA codes, access tokens or company accounts.
- Install or use unauthorised software, browser extensions or cloud services on company devices or networks.
- Download pirated software, malware or other material that could create a security or legal risk.
- Bypass or disable security controls such as antivirus, firewalls, MFA or access restrictions.
- Store or share company or client information through personal email, personal cloud storage or personal file-sharing accounts.
- Use company systems for illegal activities, fraud, harassment, discrimination or threats.
- Connect unauthorised devices or removable media to company systems without approval.
- Use company resources for excessive personal activities that interfere with work or affect network resources.
- Share confidential company or client information with people who are not authorised to receive it.

5. Reasonable Personal Use

NexusTech allows limited personal use of company devices and internet services when the use is occasional, lawful and does not interfere with work.

Personal use must not:

- Create a security risk.
- Use excessive storage, bandwidth or other company resources.
- Involve illegal, offensive or prohibited content.
- Affect work performance or the availability of company systems.
- Create an additional cost for NexusTech.
- Involve the storage or sharing of company or client information through a personal account.

- Be used to operate a personal business, conduct gambling or carry out political campaigning through company systems.

NexusTech may review the use of its systems in line with applicable law, contractual responsibilities and approved monitoring notices.

6. Roles and Responsibilities

Role	Responsibility
Employees and other users	Follow the policy, protect company accounts and devices, use approved services and report security incidents or suspected violations.
IT and Information Security	Maintain security controls, approve software where required, support users and investigate reported violations.
Managers	Make sure team members understand the policy and report repeated or serious concerns to IT, Information Security or HR.
Human Resources	Support disciplinary action where a confirmed policy violation requires it.
Information Security Manager	Maintain the policy, coordinate reviews and manage approved exceptions.

7. Compliance and Enforcement

All users within the scope of this policy are expected to comply with its requirements. NexusTech may investigate suspected violations using appropriate evidence, including Helpdesk tickets, reports, system records and security logs.

Where a violation is confirmed, the response will depend on the seriousness of the conduct, the level of harm, whether the action was deliberate and whether similar behaviour has happened before. Possible actions include additional training, removal of unauthorised software, restriction or removal of access, a formal warning, disciplinary action, termination of employment or referral to law enforcement in serious cases.

Managers must report repeated or serious violations to Information Security and Human Resources rather than ignoring them.

8. Exceptions

An exception may be considered where a genuine business need cannot be met by following the normal policy requirement.

The person requesting the exception must submit it in writing to the Information Security Manager before carrying out the activity, unless there is a genuine emergency. The request must include:

- The business reason.
- The system, device or information involved.
- The period for which the exception is needed.
- The risks created by the exception.
- The safeguards or compensating controls that will be used.

The Information Security Manager and the relevant system or data owner must review the request. Approved exceptions must have an expiry date, an identified owner and a record in the exception register. Emergency exceptions must be documented and reviewed as soon as possible after the emergency has been handled.

9. Approval and Review

This policy was approved by Marcus Vance, Chief Executive Officer, and became effective on 18 September 2026. The Information Security Manager is responsible for maintaining the policy, recording its version history and coordinating future reviews.

The policy will be reviewed at least once every twelve months. An earlier review will be carried out after a major technology change, security incident, legal or contractual change, business change or evidence that the policy is not working as intended.

All users within the scope of this policy must complete the required awareness training and acknowledge that they have read and understood the current version. New users should complete this requirement before receiving normal access to NexusTech systems.

Evidence Bundle 3: User Access Request Procedure

NexusTech Solutions User Access Request Procedure

Document Control

Document Control Field	Procedure Detail
Procedure Title	User Access Request Procedure
Version	1.0
Procedure Owner	Information Security Manager, supported by the Helpdesk Manager
Approval Authority	Marcus Vance, CEO
Applies To	Employees, contractors, temporary workers and other authorised users
Review Date	18 September 2027, or earlier if the process or systems change

1. Purpose

This procedure explains how NexusTech handles requests for access to its systems and information. It covers the process from receiving the request to approving, providing, recording and closing the access. The main purpose is to make sure that access is properly authorised and limited to what the user needs for their role.

2. Scope

This procedure applies to requests for new access, changes to existing access and removal of access. It covers access to applications, databases, cloud services, shared resources and other NexusTech systems. It also applies when an employee or contractor changes role, moves to another department or leaves the organisation.

3. Prerequisite and Authorised Roles

Before a request can be processed, the Helpdesk technician must have:

- Access to the approved ticketing system.
- A current list of managers, system owners and data owners who are authorised to approve access.
- The relevant role based permission matrix.
- An authorised Helpdesk or system administration account.
- Enough information to confirm the user's identity, department, job role and relationship with NexusTech.

- A way to record approvals, actions and evidence in the ticket.

Only authorised Helpdesk or system administration staff may create, change or remove user access. The line manager confirms the business need. The system owner or data owner gives additional approval when the request involves a particular system or sensitive information. Information Security reviews exceptions, unusual requests and access concerns.

4. Procedure Steps

Step 1: Receive the request

Receive the request through the approved ticketing system or access workflow. Do not process requests that are sent only through informal email or chat messages. Return the request to the sender and explain that the approved workflow must be used.

Step 2: Check the request details

Confirm that the ticket includes:

- The user's full name.
- Staff or contractor identification.
- Department and job role.
- The system, application or data requested.
- The type of access required.
- The business reason.
- The requested start date.
- An end date where temporary access is needed.

If information is missing, place the request on hold and ask the requester to provide it.

Step 3: Verify the identity

Verify the identity of the requester and the user through the approved identity verification method. Do not rely only on an email address if there is a concern about impersonation or an unusual request.

Confirm that the user has a valid employment or approved third party relationship with NexusTech before normal access is created.

Step 4: Check line manager approval

Check that the user's line manager has approved the request in the ticket or through the approved workflow. If approval is missing, do not continue with the request. Place it on hold and ask the manager to approve it through the correct process.

Step 5: Check system or data owner approval

Check whether the system owner or data owner must approve the request. This approval is required where the request involves sensitive, financial, health, client or privileged information.

If the required approval is missing, do not create the access. Record the missing approval and return the request for completion.

Step 6: Review the requested permissions

Compare the requested access with the user's job role and the role based permission matrix.

Apply the principle of least privilege by giving the user only the lowest level of access needed to complete the approved work. Check for duplicate accounts, unnecessary permissions, previous access and separation of duties concerns.

If the request includes access that does not match the user's role, ask for clarification or escalate it to Information Security or the relevant system owner.

Step 7: Create, change or remove the account access

Use the approved identity and access management process to create the account or update the existing account. Each user must have an individual account. Shared accounts must not be created unless there is a separately approved exception.

For an access change, update only the permissions that have been approved. For an access removal, remove the approved access and confirm that the user's previous permissions are no longer active.

Step 8: Apply required security controls

Apply the approved role and any required controls, such as multi factor authentication or an access expiry date. Do not give administrator access simply because it is easier to set up.

Temporary access must have an end date. Privileged access must follow any additional approval required by the relevant security standard.

Step 9: Test the access

Test that the approved access works as expected without giving the user more access than was authorised. Use non sensitive information for testing where possible.

If the access does not work or appears to provide too much permission, stop the process and correct the issue before notifying the user.

Step 10: Record the evidence

Record the completed actions in the ticket. The evidence should include:

- The original request.
- Manager and system or data owner approvals.

- Identity verification details.
- The access decision.
- The role or permissions applied.
- The technician's name.
- The date and time of the change.
- The expiry date, where relevant.
- Screenshots or system logs where they are allowed and useful.

Passwords, MFA codes and other secret information must not be added to the ticket.

Step 11: Notify the user and manager

Notify the user and the manager through the approved communication channel. The notification should state:

- What access was provided, changed or removed.
- The system or resource involved.
- Any conditions or expiry date.
- How the user should report a problem.
- The user's responsibility to protect the account and use the access correctly.

Step 12: Close the ticket

Close the ticket only after the request has been completed, the evidence has been recorded and the user or manager has been notified.

If the request cannot be completed, do not close it as completed. Record the reason, the current status and the next action required.

5. Emergency Request and Exceptions

An emergency request may be used when waiting for the normal process could create a serious risk to business operations, client services, people or security.

The technician must still record:

- The name of the requester.
- The system involved.
- The reason for the emergency.
- The level of access required.
- The person who gave the emergency approval.
- The time the access was granted.
- The time the access should end.

Where normal approval cannot be obtained, temporary access may be granted with verbal approval from the relevant manager. Written confirmation must then be added to the ticket within 24 hours. Emergency access must be limited to the minimum required and reviewed by the system owner or Information Security Manager after the event.

An emergency approval must not become permanent automatically. Any continuing access must go through the normal approval process. A permanent exception must be recorded in the exception register and must have an owner, reason, expiry date or review date.

6. Record Retention and Audit Trail

The access request ticket is the main audit record for the request. It must contain the request, approvals, checks, actions taken, notifications, exception information and closure details.

NexusTech must retain access request tickets for at least one year, or longer where required by a client contract, regulation, legal requirement or audit obligation. Records must be available for authorised internal or external review.

Tickets must not be deleted or changed in a way that removes the history of the decision. Access should also be reviewed when a user changes role, transfers department, takes extended leave or leaves NexusTech so that unnecessary permissions can be removed promptly.

Evidence Bundle 4: Communication and Training Plan

Rollout Plan for the Acceptable Use Policy

The purpose of this plan is to make sure employees understand the new Acceptable Use Policy and know what is expected of them. Since different groups have different responsibilities, the communication will be adjusted to suit each group rather than relying on one email.

Communication and Training Plan

Audience	Key Message	Channel	Owner	Timing	Acknowledgement	Success Measure
General Employees	The AUP explains how company devices, networks, email and other IT resources should be used. Employees must also know how to report security concerns.	Company-wide email, all-hands session, intranet notice and mandatory online training	Information Security Manager and HR	Week 1 announcement and Week 2 training	Employees read the policy, complete the training and submit an electronic acknowledgment	At least 95% complete the training and acknowledge the AUP within three weeks. Average knowledge-check score is at least 80%.
IT and Helpdesk Staff	IT staff need to understand the AUP and know how to apply the User Access Request Procedure consistently.	Technical briefing, procedure walkthrough and team meeting	Information Security Manager and IT Director	Week 1 briefing and Week 2 procedure practice	Attendance and completion of a short knowledge check	100% attendance at the technical briefing and completion of the procedure knowledge check.
Managers	Managers need to understand their responsibility for reinforcing the policy, supporting training and reporting repeated concerns.	Manager briefing, email summary and question session	Information Security Manager and HR	Week 1	Manager acknowledgment and attendance record	100% attendance or acknowledgment of the manager briefing and evidence that reminders are issued to non-compliant staff.

HR and Onboarding Staff	The AUP should be included in the onboarding process so new users understand their responsibilities before receiving normal access.	HR briefing and updated onboarding checklist	HR Manager and Information Security Manager	Week 2	Updated checklist and HR confirmation	Updated onboarding checklist implemented and all new users acknowledge the AUP before receiving normal access.
-------------------------	---	--	---	--------	---------------------------------------	--

Rollout Timeline

Time	Activity	What Happens
Week 1, Day 1	CEO announcement	The CEO announces the approved AUP, explains why it is needed and states when it takes effect.
Week 1, Days 2 to 3	Manager and IT briefings	Managers and IT staff receive information relevant to their responsibilities and have an opportunity to ask questions.
Week 1, Days 3 to 5	General employee awareness	The policy is shared through the intranet and all-hands session, and the online training module is opened
Week 2	Training and acknowledgement	Employees complete the training, knowledge check and electronic acknowledgement.
Week 3	Follow-up	Information Security checks completion and reminds employees who have not completed the requirements.
After 30 days	Effectiveness review	The policy owner reviews training completion, acknowledgement, knowledge check results and common questions to identify any gaps.

Acknowledgement Method

All employees will complete the acknowledgement through the Learning Management System. They will be required to open the current version of the Acceptable Use Policy, complete a short knowledge check and confirm that they understand their responsibilities.

The acknowledgement statement will read:

"I confirm that I have read the NexusTech Acceptable Use Policy, understand the responsibilities that apply to me and know how to report a security concern."

The Learning Management System will record the employee's name, the date of completion, the policy version and the completion status. This gives NexusTech evidence that the correct version of the policy was provided and acknowledged.

Measuring Effectiveness

The rollout will be measured using the following indicators:

- **Training completion rate:** At least 95 percent of employees should complete the mandatory training within three weeks of the announcement.
- **Policy acknowledgement rate:** At least 95 percent of employees should formally acknowledge the policy by the deadline.
- **Knowledge check results:** The average score should be at least 80 percent. Employees who do not achieve this score should receive clarification or additional training.
- **Implementation evidence:** IT will review access tickets and reported concerns to check whether staff are following the approved process and reporting problems correctly.

Escalation for Non Compliance

Employees who do not complete the training or acknowledge the policy by the deadline will first receive a reminder from their manager. If there is still no response after one week, HR will issue a formal follow up notice.

If an employee repeatedly misunderstands the policy, fails the knowledge check or continues to break the rules, the matter will be referred to the employee's manager and HR for additional coaching or further action. Suspected serious misuse or security violations will also be referred to the Information Security team for investigation. Any action taken should be recorded and should be appropriate to the seriousness of the issue.

Evidence Bundle 5: Policy Review and Maintenance Memo

Policy Review Memo

To	Information Security Steering Committee
From	Mercy Ajayi, Information Security Manager
Date	September 2027
Subject	Review of the Acceptable Use Policy following cloud migration and data sharing incident

The Acceptable Use Policy needs to be reviewed because two important events have occurred. First, NexusTech has migrated its primary database to AWS, which changes how and where company and client information is stored and accessed. Second, an employee shared a sensitive document through a personal cloud storage account. Although this is already prohibited by the current policy, the incident shows that the rules around personal cloud accounts and approved storage platforms may need to be clearer. The review should involve the Information Security and IT teams, Legal or Compliance, relevant system and data owners, and a representative from a business unit that works with the AWS environment. The team should review the recent incident, current cloud data handling practices, access controls, previous training and acknowledgement records, and any relevant legal or contractual requirements. This will help determine whether the gap came from the policy wording, user understanding, or both. The review team should also conduct a documented risk analysis that assesses the likelihood and impact of unauthorised access, data leakage, insecure AWS configuration and inappropriate external sharing.

Based on the review, I propose adding a clear section on approved cloud storage platforms and how company and client information should be handled in these environments. The policy should also clearly state that sensitive information must not be stored or shared through personal cloud accounts or other unapproved file sharing platforms. Where external sharing is allowed, the policy should state who is authorised to approve it and what records should be kept.

The Information Security Manager will remain the policy owner and will lead the update. The revised policy should be reviewed by the Information Security Steering Committee and approved by the CEO, Marcus Vance, before it takes effect. Going forward, the AUP should be reviewed annually, with an earlier review when there is a major technology or cloud change, a security incident involving data handling, or a significant legal or contractual change. After approval, the updated policy should be communicated to users and a new acknowledgement should be completed so that employees confirm they have received the current version.

References

American Institute of Certified Public Accountants. (2022). *SOC 2: Trust Services Criteria*.

International Cybersecurity and Digital Forensics Academy. (2026). *GRC102 Week 2 practical laboratory: Developing security policies and procedures*. Course material.

International Organization for Standardization. (2022a). *ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection, Information security management systems, Requirements*.

International Organization for Standardization. (2022b). *ISO/IEC 27002:2022: Information security, cybersecurity and privacy protection, Information security controls*.

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*.